

SEGURANÇA DA INFORMAÇÃO

INTRODUÇÃO

No cenário atual da transformação digital, a segurança no acesso aos recursos digitais tornou-se central para a proteção da informação. Autenticação, autorização e controle de acesso deixaram de ser apenas ferramentas técnicas, passando a ocupar posição estratégica na defesa de identidades, dados e infraestruturas críticas. A autenticação garante que a entidade é de fato quem afirma ser; a autorização define suas permissões; e o controle de acesso regula o uso desses recursos conforme regras estabelecidas.

Diante do aumento de ataques direcionados ao roubo de credenciais e à elevação de privilégios, ganha relevância o uso de soluções como autenticação multifator (MFA), controle baseado em atributos (ABAC), gerenciamento de identidades (IAM) e a arquitetura Zero Trust. Essas práticas revelam uma transição conceitual: a confiança, antes centrada no perímetro da rede, agora recai sobre a identidade e o comportamento dos usuários.

TEMA 1 – FUNDAMENTOS E MODELOS DE CONTROLE DE ACESSO

A discussão sobre autenticação, autorização e controle de acessos começa pelo domínio dos fundamentos que sustentam a segurança da informação em qualquer arquitetura computacional. Compreender os princípios que regem a proteção de dados, como confidencialidade, integridade e disponibilidade, por exemplo, é indispensável para o desenho de políticas eficazes de acesso.

1.1 Conceitos de autenticação, autorização e auditoria

Compreendermos os termos *autenticação*, *autorização* e *auditoria* nos permite estabelecer processos de defesa da informação, pois violações podem ocorrer em diversas esferas. Neste sentido, Lyra (2017) questiona

Existe alguma coisa que pode ser feita para evitar que um incidente ocorra? Ou então reduzir os riscos de [...] violar o banco de dados de sua empresa? Sim, existe, e são soluções simples que podem fazer toda a diferença. (Lyra, 2017, p. 88)

O Item 09 da norma ISO/IEC 27002 recomenda medidas de proteção, regras de acesso e outros pormenores defensivos referentes ao acesso às informações. De modo geral, segundo a norma, nada deve ser permitido, tudo é proibido, a menos que expressamente autorizado.

A autenticação consiste na verificação da identidade do usuário que acessa recursos computacionais, sendo baseada em três métodos principais: o que o usuário sabe (como senhas complexas e atualizadas), o que possui (cartões magnéticos, tokens ou smart cards) e o que é (dados biométricos como impressão digital, reconhecimento facial ou de íris) (Ferreira; Araujo, 2008; Lyra, 2017; Fortinet, 2025). Esses métodos garantem a singularidade do acesso por meio de credenciais seguras e personalizadas.

A autorização segue a autenticação e consiste na definição dos privilégios de acesso concedidos a um usuário dentro de um sistema ou rede. Enquanto a autenticação tem como objetivo verificar a identidade do indivíduo por meio de credenciais como senhas, certificados ou biometria, a autorização estabelece quais ações esse usuário está apto a realizar e quais recursos pode acessar com base em sua função ou perfil previamente definido (Fontes, 2015).

A auditoria, por sua vez, constitui um mecanismo essencial para o monitoramento contínuo das atividades dos usuários durante sua conexão a uma rede (Fortinet, 2025). Esse processo envolve o registro detalhado de diversos dados, como o tempo total de conexão, a quantidade de informações transmitidas e recebidas, o endereço de protocolo de Internet (IP), os identificadores uniformes de recursos (URIs) acessados e os serviços utilizados ao longo da sessão.

O objetivo da auditoria vai além da simples coleta de dados, sendo amplamente utilizada para a análise de padrões de comportamento dos usuários, a verificação de conformidade com as políticas institucionais e a elaboração de registros capazes de embasar processos de cobrança e faturamento (Lyra, 2017). Ao explorar os registros gerados durante o acesso, é possível, por exemplo, auditar a atividade do usuário com precisão e rastreabilidade, fornecendo subsídios técnicos para a tomada de decisões estratégicas e operacionais. Para Voltz (2022), o conceito de auditoria está associado a um processo.

De acordo com o autor,

Todo sistema deve seguir um processo, a fim de torná-lo produtivo e eficiente. Alguns deles têm suas normas estabelecidas pelo governo em forma de lei, enquanto outros dispõem de normas estabelecidas por órgãos competentes no tema. A ação de verificar se os processos estão em conformidade é intitulada auditoria e, quando esse processo está focado na análise de conformidade de hardware, software e redes, é chamado de auditoria de sistemas de informação. (Voltz, 2022, p. 9)

Em contextos nos quais há cobrança proporcional ao tempo de uso, como em serviços tarifados por hora de conexão, por exemplo, os registros de acesso produzidos por sistemas contábeis permitem identificar a duração exata das sessões, vinculando esse tempo aos dispositivos ou usuários específicos conectados aos recursos da rede, como roteadores ou servidores.

TEMA 2 – MODELOS CLÁSSICOS: DAC, MAC, RBAC, ABAC

No âmbito da segurança da informação, os modelos de controle de acesso representam estruturas essenciais para a definição de políticas que assegurem a autorização apropriada de usuários a sistemas e dados. Ao estabelecer critérios sobre quem pode acessar quais recursos e sob quais condições, modelos como DAC, MAC, RBAC e ABAC contribuem para a mitigação de riscos operacionais e a preservação da confidencialidade, integridade e disponibilidade das informações. Compreendemos suas características, vantagens e limitações é fundamental para a implementação de ambientes computacionais seguros e alinhados às exigências normativas e organizacionais.

2.1 Modelo DAC (Discretionary Access Control)

O modelo conhecido como DAC (Discretionary Access Control, ou Controle de Acesso Discrecional) é determinado pelo proprietário do recurso. Ele tem autonomia para conceder ou revogar permissões de leitura, escrita ou execução a outros usuários. Embora seja flexível e fácil de implementar, o DAC é mais suscetível a erros humanos e ataques de escalonamento de privilégios, sendo menos adequado em ambientes que exigem alto grau de segurança. Segundo Penelova (2021),

Muitas vezes, o proprietário de um objeto é o seu criador. O acesso a um objeto DAC é regulado de acordo com a identidade do usuário. As políticas de DAC têm maior aplicação devido à sua flexibilidade. O DAC não é suficiente para garantir a segurança de um sistema, e é por isso que este modelo de controle de acesso é introduzido juntamente com o

MAC. O DAC é aplicado em sistemas operacionais em combinação com outros modelos de controle de acesso. (Penelova, 2021, p. 80)

Como vemos, o modelo DAC, embora amplamente utilizado pela sua flexibilidade, apresenta limitações significativas quando adotado isoladamente, sobretudo no que se refere à robustez da segurança dos sistemas. Sua principal fragilidade reside na excessiva delegação de responsabilidade aos proprietários dos objetos, que têm autonomia para definir e modificar as permissões de acesso.

2.2 Modelo MAC (Mandatory Access Control)

O modelo MAC (Mandatory Access Control, ou Controle de Acesso Obrigatório) tem por premissa que o acesso às informações é controlado por regras obrigatórias, ou seja, não podem ser alteradas pelos usuários finais. Essas regras são aplicadas por meio de um sistema de etiquetas de segurança que classificam tanto os usuários quanto os objetos, criando uma estrutura em forma de grade ou grelha de níveis de segurança (Penelova, 2021).

No MAC, cada usuário recebe uma autorização de segurança (ou clearance) que indica seu nível de confidencialidade, enquanto os objetos (como arquivos ou recursos) têm uma classificação de segurança, que determina seu nível de sensibilidade. O fluxo de informação é orientado e unidirecional, seguindo as diretrizes: por exemplo, um usuário pode ler informações de nível superior (proteção de confidencialidade) mas não pode escrever em objetos de nível inferior (para evitar vazamentos).

2.3 Modelo RBAC (Role-Based Access Control)

Por sua vez, o modelo RBAC (Role-Based Control Access, ou Controle de Acesso Baseado em Papéis), que foi apresentado no trabalho de Sandhu, Coyne, Feinstein e Youman (1996), atualmente é um dos modelos de controle de acesso mais utilizados, especialmente em ambientes empresariais. Nesse modelo, as permissões de acesso são atribuídas a papéis (roles), e os usuários são atribuídos a esses papéis conforme suas funções na organização.

Sandhu, Coyne Feinstein e Youman (1996), assim como Pelenova (2021), são consonantes quanto às vantagens desse modelo, visto que ele se destaca por sua flexibilidade, ao permitir o gerenciamento eficiente de permissões por meio da modificação dos direitos atribuídos a uma função, o que automaticamente reflete em todos os usuários vinculados a ela.

Essa abordagem também promove maior segurança, uma vez que facilita a implementação de políticas de acesso alinhadas às funções institucionais previamente definidas. Além disso, apresenta elevada escalabilidade, sendo particularmente eficaz na administração de ambientes complexos e com grande número de usuários e níveis de permissão.

Além disso, o RBAC suporta características como hierarquias de papéis (em que papéis podem herdar permissões de outros papéis), separação de deveres e restrições específicas, aprimorando ainda mais o controle da segurança da informação.

2.4 Modelo ABAC (Attribute-Based Access Control)

Neste modelo, é utilizado um conjunto de atributos (do usuário, do recurso, da ação e do ambiente) para tomar decisões de acesso. É o modelo mais dinâmico e granular, permitindo políticas sofisticadas e adaptáveis, mas também exigindo maior complexidade na implementação e manutenção.

Segundo Pelenova (2021, p. 82),

o mecanismo de controle de acesso ABAC consiste em um Ponto de Decisão de Política e um Ponto de Aplicação de Política, permitindo que sujeitos e objetos que ainda não existem no sistema sejam incluídos em uma política.

TEMA 3 – GESTÃO DE IDENTIDADES E GOVERNANÇA DE ACESSO (IAM)

Se a autenticação identifica e a autorização concede, a gestão de identidades e acessos (IAM – Identity and Access Management) representa o sistema que organiza, monitora e audita todo esse processo. A identidade digital, entendida como a representação de um sujeito nos sistemas computacionais, tem seu ciclo de vida pautado por eventos como criação, alteração, suspensão e revogação.

O gerenciamento eficaz dessas etapas é crucial para evitar acessos indevidos, especialmente em organizações complexas, sujeitas à rotatividade de pessoal, múltiplos sistemas e conformidade com regulamentações. Neste tema, são discutidos os conceitos de provisionamento automático, revisões periódicas de acesso, segregação de funções e governança de identidades, tudo isso apoiado por plataformas especializadas.

3.1 Ciclo de vida da identidade digital (criação, modificação, revogação)

O ciclo de vida da identidade digital, elemento central na gestão de identidades (IAM), compreende as etapas de criação, modificação e revogação de acessos, garantindo que usuários e dispositivos autorizados tenham permissões adequadas no tempo e contexto corretos. Segundo a Microsoft (2025), a identidade é definida por atributos e propriedades que orientam os sistemas no controle de acesso, assegurando segurança, conformidade e eficiência operacional.

A etapa de criação, também denominada provisionamento da identidade, ocorre no momento em que um novo usuário, colaborador, cliente ou dispositivo necessita acessar serviços ou sistemas corporativos. Nesse estágio, estabelece-se uma identidade digital única, composta por atributos como nome, função, credenciais (senhas, biometria ou certificados digitais) e perfis de acesso específicos.

Os direitos iniciais são atribuídos conforme a função ou o contexto organizacional do sujeito, como o departamento ou o projeto ao qual está vinculado. Em ambientes organizacionais maduros, esse processo tende a ser automatizado, integrando-se a sistemas de recursos humanos ou cadastros de clientes, o que minimiza falhas operacionais e reduz a latência no provisionamento de acessos.

Na fase ativa da identidade digital, ajustes contínuos de acesso ocorrem conforme mudanças funcionais ou administrativas. Ferramentas de IAM permitem gerenciar essas modificações com precisão, assegurando o princípio do menor privilégio e mantendo rastreabilidade completa das ações. Esse controle é essencial para garantir acessos estritamente necessários às funções dos usuários.

A última etapa do ciclo, a revogação (ou desprovisionamento), ocorre quando a identidade não é mais necessária, seja por desligamento do colaborador, término de contrato, conclusão de projeto ou obsolescência de um dispositivo. Nessa fase, todos os acessos associados à identidade são eliminados de forma controlada e célere, evitando a existência de contas órfãs que possam ser exploradas indevidamente. A automação da revogação é essencial para conter os riscos associados a ameaças internas, sobretudo em ambientes com estruturas dinâmicas ou distribuídas.

Dessa forma, o ciclo de vida da identidade digital constitui uma estrutura abrangente e crítica para o controle de acesso em ambientes digitais. A adequada implementação e monitoramento de suas três fases é indispensável para promover segurança da informação, conformidade regulatória e governança organizacional efetiva.

3.2 Ferramentas e soluções IAM (Okta, Azure AD, ForgeRock)

O IAM constitui uma estrutura essencial para assegurar que os usuários corretos tenham acesso apenas aos recursos adequados, no momento apropriado e pelas razões justificadas. No contexto corporativo, soluções de IAM desempenham papel fundamental na proteção dos ativos informacionais, contribuindo para a governança, conformidade e segurança operacional. Shechnick (2023) apresenta algumas ferramentas amplamente utilizadas, como Okta, Azure Active Directory (Azure AD) e ForgeRock, que representam abordagens robustas e distintas para a gestão de identidades e acessos em diferentes ambientes organizacionais.

Segundo defendido por McDade (2025), a Okta é uma plataforma baseada na nuvem, amplamente reconhecida por sua especialização em autenticação multifator (MFA) e Single Sign-On (SSO), facilitando o acesso unificado a múltiplas aplicações. Seus recursos incluem um diretório universal para gerenciamento centralizado de usuários, grupos e dispositivos, controle do ciclo de vida de identidades, gateway de acesso e gerenciamento de acesso a APIs.

Já o Azure Active Directory, solução da Microsoft, foca na integração com o ecossistema corporativo da empresa, abrangendo serviços como o Office 365 e a plataforma Azure. Entre seus principais recursos estão a sincronização de senhas, a autenticação para aplicações locais e em nuvem, a autenticação multifator e o controle de acesso baseado em grupos.

A ForgeRock, por sua vez, oferece uma plataforma modular e completa de IAM, com foco em autenticação, autorização, governança e controle de acesso. Seus principais recursos incluem autenticação avançada de usuários, gerenciamento do ciclo de vida de identidades, diretórios seguros e gateways de identidade. A ferramenta é altamente flexível e escalável, permitindo personalização de soluções conforme a complexidade e especificidade das demandas organizacionais.

Como propõe Marchi (2024) sobre essa ferramenta,

Essas soluções estão em vantagem devido à sua capacidade de integrar diversos aspectos do gerenciamento de identidades em um sistema integrado e adaptável, alinhando-se bem ao conceito de “Identity Fabric”. Além disso, sua ampla adoção, escalabilidade e funcionalidades avançadas são fatores chave que as destacam no mercado.

Outras soluções relevantes no ecossistema de IAM incluem o Ping Identity, com foco em segurança e experiência do usuário, o CyberArk, especializado em gerenciamento de acesso privilegiado (PAM – Privileged Access Management) e o SailPoint, voltado à governança e ao gerenciamento de riscos relacionados à identidade.

De certa maneira, podemos concluir que as soluções Okta, Azure AD e ForgeRock representam abordagens distintas e complementares no ecossistema de gerenciamento de identidades e acessos. A escolha da ferramenta mais adequada deve considerar fatores como infraestrutura tecnológica existente, exigências de integração, criticidade dos recursos acessados e requisitos específicos de segurança e conformidade.

3.3 Controle de acesso baseado em funções e atributos

Conforme Lindemulder e Kosinski (2024), o controle de acesso baseado em funções (RBAC) associa permissões às funções organizacionais, permitindo que os usuários as herdem automaticamente ao assumirem determinada função. Já o controle baseado em atributos (ABAC) considera características contextuais e individuais para definir acessos, configurando abordagens distintas, mas complementares na gestão de permissões.

O modelo RBAC destaca-se por sua simplicidade, escalabilidade e gestão centralizada de permissões, sendo eficaz em organizações de médio e grande porte. Contudo, sua rigidez limita a aplicação em contextos que exigem controle mais granular, como critérios de localização, tempo ou dispositivo de acesso.

O modelo ABAC adota uma abordagem flexível e contextual, baseando as decisões de acesso na combinação de atributos do usuário, do recurso e do ambiente. Isso permite controles mais precisos, como restringir o acesso a um arquivo conforme o projeto, o dispositivo utilizado e o horário de operação autorizado pela política organizacional.

Conforme descrito por Lindemulder e Kosinski (2024), o modelo ABAC destaca-se por sua granularidade e flexibilidade, sendo especialmente eficaz em ambientes que demandam controle contextualizado, sensível ao risco ou conformidade normativa. No entanto, sua implementação é mais complexa, exigindo conhecimento técnico especializado, políticas bem definidas e infraestrutura capaz de processar decisões de acesso em tempo real, o que pode afetar o desempenho em certos contextos. O quadro a seguir apresenta um comparativo entre essas duas estratégias.

Quadro 1 – Comparativo entre duas estratégias

Característica	RBAC	ABAC
Modelo de acesso	Baseado em funções	Baseado em atributos
Granularidade	Menos granular	Mais granular
Flexibilidade	Menos flexível	Mais flexível
Complexidade	Mais simples	Mais complexo
Desempenho	Geralmente mais rápido	Pode ser mais lento

Fonte: Athayde, 2025.

Dessa forma, a escolha entre RBAC e ABAC dependerá do grau de complexidade dos requisitos de acesso da organização. Em muitos casos, adotar um modelo híbrido que combine a simplicidade do RBAC com a flexibilidade do ABAC tem se mostrado uma estratégia eficaz para alcançar tanto a governança quanto a adaptabilidade desejada no controle de acessos.

TEMA 4 – SEGURANÇA EM AMBIENTES MODERNOS (CLOUD, MOBILE E DEVOPS)

A migração de sistemas para a nuvem, o uso massivo de dispositivos móveis e a adoção de práticas ágeis de desenvolvimento (DevOps) colocam novas exigências sobre a segurança de acessos.

Neste cenário, em que o perímetro tradicional de segurança se dissolve, o controle de acesso deve se adaptar para proteger recursos distribuídos, APIs expostas e pipelines automatizados.

Este tópico explora o conceito de identidade como novo perímetro, princípio que sustenta modelos como o Zero Trust Architecture, nos quais nenhuma requisição é confiável por padrão, mesmo que originada dentro da rede. São abordadas ainda práticas específicas de controle de acesso nos principais provedores de nuvem (AWS, Azure, GCP), estratégias para proteger ambientes de integração contínua e o uso de autenticação federada entre múltiplos domínios.

4.1 Identidade como novo perímetro (Zero Trust Architecture)

Garey (2024) nos mostra que, atualmente, tem-se visto uma inflexão paradigmática na segurança da informação diante da consolidação dos ambientes em nuvem, da mobilidade e dos processos DevOps. Nesse sentido, a “identidade” emerge como o novo perímetro, desmaterializando os limites tradicionais das redes físicas. A arquitetura Zero Trust (ZT) opera sobre um princípio fundamental: “nunca confiar, sempre verificar”. Isso implica que nenhuma entidade, usuário, dispositivo ou aplicação tem confiança implícita, independentemente de sua posição na rede, seja interna ou externa.

Esse modelo, descrito por organismos como o NIST (2020), utiliza múltiplos mecanismos de autenticação e autorização, validando incessantemente os acessos e minimizando superfícies de ataque, tornando-se particularmente relevante ante os desafios de ambientes cloud, mobilidade e trabalho remoto. A centralidade da identidade significa que controles como MFA, políticas adaptativas e monitoramento comportamental substituem os antigos muros digitais, promovendo uma resiliência dinâmica e contexto sensível.

4.2 Controle de acesso em nuvem (AWS IAM, Azure RBAC)

No universo cloud, a granularidade e a precisão dos controles de acesso são indispensáveis para garantir o princípio do menor privilégio e a segregação de funções (Microsoft, 2025). Soluções como AWS Identity and Access Management (IAM) e Azure Role-Based Access Control (RBAC) corporificam esses preceitos.

No AWS IAM, a atribuição de permissões ocorre por meio de políticas (JSON), perfis, grupos e funções, permitindo a customização fina dos acessos aos recursos cloud, bem como o gerenciamento de credenciais temporárias e integração com provedores externos de identidade.

Por outro lado, para Lindemulder e Kosinski (2024), o RBAC do Azure opera com atribuição de papéis predefinidos ou personalizados a usuários, grupos e aplicações, determinando ações e escopos específicos (assinaturas, grupos de recursos, recursos individuais) por meio de hierarquias de herança. Isso viabiliza o controle matizado do ciclo de vida de acessos, reduzindo riscos de privilégios excessivos e facilitando auditoria e conformidade.

4.3 Segurança em aplicações móveis, APIs e ambientes CI/CD

A ubiquidade dos dispositivos móveis e a adoção massiva de APIs intensificaram as demandas por abordagens de segurança multifacetadas. Em aplicações móveis, práticas basilares incluem o uso de criptografia forte, controles anti-tampering, gestão rigorosa de segredos e atualização ágil de vulnerabilidades.

No contexto de APIs, torna-se premente adotar análise de comportamento (machine learning), autenticação robusta (Ex.: OAuth, OpenID Connect), versionamento seguro e inspeção contínua das interfaces para prevenir abuso, vazamentos e ataques aos fluxos de dados sensíveis.

Em ambientes de integração e entrega contínuas (CI/CD), a segurança não pode ser postergada para etapas finais. O movimento shift-left preconiza a inserção de práticas de segurança desde o início do pipeline, como análise estática e dinâmica de código, verificação de dependências, validação de segredos e automação de compliance.

4.4 Autenticação federada e integração entre ambientes híbridos

A consolidação de ambientes híbridos (on-premises e cloud) demanda mecanismos de autenticação e identidade federadas para garantir uma experiência coesa e segura aos usuários. As arquiteturas de federação, baseadas em protocolos como SAML, OAuth2 e OpenID Connect, possibilitam Single Sign-On (SSO) entre múltiplos domínios, reduzindo a fricção para o usuário e reforçando o controle centralizado de acessos.

No âmbito corporativo, a integração entre diretórios locais (ex.: Active Directory) e plataformas de identidade em nuvem (Azure AD, Google Cloud Identity) permite a administração unificada, provisionamento e revogação ágil de

identidades e monitoramento centralizado, blindando a organização contra desvios de privilégio e exfiltração de credenciais.

Desta maneira, o cenário contemporâneo impõe a adoção de práticas que tratam a identidade como núcleo das estratégias de defesa, desmaterializam perímetros e integram controles dinâmicos capazes de acompanhar a complexidade e o dinamismo dos ambientes cloud, mobile e DevOps.

TEMA 5 – TENDÊNCIAS E NORMAS

Por fim, é fundamental que o estudo das práticas de controle de acesso se articule com as normas técnicas, as regulamentações legais e as tendências emergentes do setor. Organizações precisam alinhar suas políticas de autenticação e autorização com diretrizes internacionais, como as normas ISO/IEC 27001 e 27002, os guias do NIST, bem como legislações como a Lei Geral de Proteção de Dados (LGPD) e o General Data Protection Regulation europeu (GDPR). Ao mesmo tempo, novas abordagens vêm sendo discutidas, como a autenticação adaptativa baseada em risco, o uso de blockchain para identidade descentralizada e a aplicação de Inteligência Artificial (IA) para detecção de comportamentos anômalos.

5.1 Normas e boas práticas (ISO 27001/27002, NIST, LGPD/GDPR)

As normas ISO/IEC 27001 (2022) e 27002 (2022) constituem o esteio regulatório internacional para a gestão da segurança da informação, definindo requisitos e diretrizes para a construção de um sistema de gestão (SGSI) eficaz. A ISO 27001 orienta sobre os controles que devem ser implementados para assegurar a confidencialidade, integridade e disponibilidade da informação, incluindo aspectos de controle de acesso, políticas de segurança e monitoramento.

No mesmo sentido, os guias do NIST (2020), como os publicados pelo National Institute of Standards and Technology, complementam esse arcabouço ao fornecer frameworks detalhados como o NIST Cybersecurity Framework (CSF) e revisões específicas sobre autenticação e autorização, pautando-se pela flexibilidade e adaptação às realidades das organizações, enfatizando a gestão de risco e a avaliação contínua. Paralelamente, as legislações de proteção de dados, exemplificadas pela LGPD e pelo GDPR, impõem obrigações jurídicas que

impactam diretamente as políticas de controle de acesso, exigindo que o tratamento de dados pessoais ocorra sob bases legais claras, com medidas técnicas adequadas para mitigar riscos de vazamento e acesso não autorizado.

A convergência desses instrumentos normativos guia as organizações na adoção de práticas que contemplam requisitos técnicos e de governança, fomentando um ambiente de segurança integrado e em conformidade legal.

5.2 Inteligência artificial e autenticação adaptativa

A evolução tecnológica tem propiciado o surgimento de mecanismos de autenticação adaptativa que se fundamentam na utilização de IA para a análise dinâmica e em tempo real dos riscos associados a cada tentativa de acesso. Essa abordagem transcende os modelos tradicionais estáticos, adotando uma perspectiva contextualizada e sistêmica.

A autenticação adaptativa baseada em risco calcula continuamente a probabilidade de ameaça com base em diversos fatores, tais como localização geográfica do usuário, dispositivo usado, comportamento habitual, horário de acesso, entre outros dados contextuais. A IA e algoritmos de machine learning são empregados para detectar anomalias e padrões fora do comum, ajustando o rigor da autenticação de forma proporcional ao risco identificado. Neste sentido, Rodrigues (2025, p. 7) infere que

[...] a aplicação da IA na segurança é talvez uma das mais críticas, pois envolve a proteção de vidas, patrimônio e a manutenção da ordem pública. Sistemas de IA são empregados para monitorar atividades suspeitas, prever crimes e melhorar a resposta a emergências, mas também levantam questões éticas sobre privacidade e vigilância.

Na prática, isso significa que para acessos considerados de baixo risco, a fricção na autenticação pode ser reduzida para otimizar a experiência do usuário legítimo. Por outro lado, para situações de maior risco, são acionadas camadas adicionais, como múltiplos fatores (MFA), verificações biométricas ou outras medidas complementares.

Essa dinâmica promove um equilíbrio entre usabilidade e segurança, representando uma resposta inteligente às ameaças contemporâneas e às demandas pelos fluxos contínuos e heterogêneos dos ambientes modernos.

5.3 Blockchain e identidade descentralizada

No contexto da descentralização digital, o blockchain emerge como uma tecnologia revolucionária para o gerenciamento da identidade digital, propondo um modelo no qual o controle da identidade não reside em uma única entidade centralizada, sendo distribuído em uma rede confiável e imutável.

A identidade descentralizada baseada em blockchain permite que os usuários detenham suas credenciais, que são verificadas por terceiros confiáveis, sem que seja necessária a exposição ou centralização dos dados pessoais em repositórios vulneráveis. Esse modelo reduz o risco de comprometimentos massivos e melhora a privacidade, alinhando-se com os preceitos das legislações de proteção de dados.

Estudos de caso indicam que tais soluções são promissoras especialmente em contextos de múltiplos provedores de serviços, ambientes híbridos e federados, nos quais a interoperabilidade, a auditabilidade e a segurança criptográfica são decisivas. O blockchain viabiliza a construção de sistemas mais resilientes, auditáveis e transparentes, potencializando a governança da identidade e ampliando a autonomia do usuário sobre seus dados.

A convergência entre normas robustas, inovações tecnológicas como a IA aplicada à autenticação adaptativa e paradigmas disruptivos representados pelo blockchain delinea o horizonte da segurança da informação. Esta tríade atende às exigências da complexidade dos ambientes digitais atuais e projeta um cenário em que as práticas de controle de acesso tendem a se tornar mais inteligentes, confiáveis e voltadas à proteção eficaz dos ativos e direitos dos usuários e organizações.

REFERÊNCIAS

AUTORIZAÇÃO PARA ANÁLISE em escala de nuvem no Azure. **Microsoft**, 2025. Disponível em: <<https://learn.microsoft.com/pt-br/azure/cloud-adoption-framework/scenarios/cloud-scale-analytics/secure-authorization>>. Acesso em: 19 ago. 2025.

FERREIRA, F. N. F.; ARAÚJO, M. T. de. **Política de segurança da informação**: guia prático para elaboração e implementação. 2. ed. Rio de Janeiro: Ciência Moderna, 2008.

FONTES, E. L. G. Políticas de segurança da informação. Rio de Janeiro: Escola Superior de Redes, 2015.

GAREY, L. O que é segurança de confiança zero? **Oracle**, 7 out. 2024. Disponível em: <<https://www.oracle.com/br/security/what-is-zero-trust/>>. Acesso em: 19 ago. 2025.

GOVERNE O CICLO de vida do funcionário e do convidado com o Microsoft Entra ID Governance. **Microsoft**, 2025. Disponível em: <<https://learn.microsoft.com/pt-br/entra/id-governance/scenarios/govern-the-employee-lifecycle>>. Acesso em: 19 ago. 2025.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27001:2022**. Information Security, Cybersecurity and Privacy Protection – Information Security Management Systems – Requirements. Genebra: ISO, 2022. Disponível em: <<https://www.iso.org/standard/82875.html>>. Acesso em: 19 ago. 2025.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27002:2022**. Code of Practice for Information Security Controls. Genebra: ISO, 2022. Disponível em: <<https://www.iso.org/standard/75652.html>>. Acesso em: 19 ago. 2025.

LINDEMULDER, G.; KOSINSKI, M. What is role-based access control (RBAC)? IBM, 2025. Disponível em: <<https://www.ibm.com/think/topics/rbac>>. Acesso em: 19 ago. 2025.

LYRA, M. R. **Segurança e auditoria em sistemas de informação**. 2. ed. Rio de Janeiro: Ciência Moderna, 2017.

MARCHI, W. O que significa o termo “Identity Fabric”? **Identity Academy**, 29 jul. 2024. Disponível em: <<https://www.identityacademy.com.br/post/o-que-significa-o-termo-identity-fabric>>. Acesso em: 19 ago. 2025.

MCDADE, M. The top 12 identity and access management solutions. **Expert Insights**, 2025. Disponível em: <<https://expertinsights.com/identity-and-access-management/top-identity-and-access-management-solutions#okta-workforce-identity-cloud>>. Acesso em: 19 ago. 2025.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **Special Publication 800-207**: Zero Trust Architecture. Gaithersburg, MD: NIST, 2020. Disponível em: <<https://doi.org/10.6028/NIST.SP.800-207>>. Acesso em: 19 jul. 2025.

O QUE É AUTENTICAÇÃO, autorização e contabilidade (AAA)? **Fortinet**, 2025. Disponível em: <<https://www.fortinet.com/br/resources/cyberglossary/aaa-security>>. Acesso em: 19 ago. 2025.

PENELOVA, M. Access control models. **Cybernetics and Information Technologies**, v. 21, n. 4, p. 77-104, 2021.

RODRIGUES, W. B. Aplicação de inteligência artificial na detecção de ameaças em redes de computadores. **Revista Di Fatto**, Joinville, v. 4, 2025. Disponível em: <<https://revistadifatto.com.br/artigos/aplicacao-de-aplicacao-de-inteligencia-artificial-na-deteccao-de-ameacas-em-redes-de-computadores/>>. Acesso em: 19 ago. 2025.

SANDHU, R. S. et al. Role-based control models. **IEEE Computer**, v. 29, n. 2, p. 37-48, fev. 1996.

SHECHNICK, M. Melhores ferramentas IAM para 2024: gerenciamento seguro de identidade e acesso. **Silverfort**, 1º out. 2023. Disponível em: <<https://www.silverfort.com/pt/blog/best-iam-tools/>>. Acesso em: 19 ago. 2025.

VOLTZ, W. M. **Segurança e auditoria de sistemas**. Curitiba: IESDE Brasil, 2022.